Security Management Program Deficiencies and Evaluation Report

TO: Senior Leadership, Sandhaven University
FROM: Cybersecurity Risk and Governance Advisory
DATE: September 25, 2026
SUBJECT: Post-Incident Analysis and Security Program Remediation (Case Study RSN1)

A. Security Management Program Deficiencies and Evaluation

1. Organization Identification

Organization Name: Sandhaven University (SU)

Sandhaven University is a private, nonprofit higher education institution based in Los Angeles, California, with two satellite campuses, enrolling 25,000 students and employing 2,500 faculty and administrative staff. SU manages cloud platforms, student information systems, health clinic data, and sensitive faculty research data.

2. Identified Deficiencies in Security Management Program

Deficiency 1: Absence of a Vulnerability Management Program and Patch Governance Structure

- **Post-Incident Evidence:** Post-Incident Report 1 reveals that Sandhaven University deployed an outdated version of MOVEit Transfer (2020.0.X / v12.0) without any documentation, schedules, or procedures for software updates, vulnerability identification, or patching. When a critical zero-day vulnerability (CVE-2023-34362) emerged, IT staff submitted a generic service request instead of executing an emergency patching playbook. As a result, foreign threat actors exploited the system for approximately 90 days, exfiltrating sensitive research data and student financial records.
- **Programmatic Root Cause:** The university lacks centralized technology lifecycle governance and patch management software, delegating system upkeep to system owners and relying on four network administrators who manage security duties only as secondary tasks.

Deficiency 2: Absence of Continuous Security Monitoring, Network Segmentation, and Incident Escalation Protocols

- **Post-Incident Evidence:** Post-Incident Reports 1 and 2 highlight critical gaps in monitoring, network controls, and incident escalation. In Incident 1, active data exfiltration continued for 90 days unnoticed due to a lack of continuous network monitoring and unconfigured edge firewalls. In Incident 2, a malicious email attachment containing TrickBot malware, Cobalt Strike beacons, and Maze ransomware executed undetected, spreading laterally across 100% of the active hosts in the College of Healthcare facility. Furthermore, university leadership transferred $100,000 in Ethereum to cybercriminals without notifying law enforcement or filing insurance claims.
- **Programmatic Root Cause:** The university lacks a centralized Security Operations Center (SOC) or SIEM/EDR detection tooling, fails to enforce network segmentation between facility

hosts and central enterprise environments, and operates without formal incident escalation pathways or legal reporting frameworks.

3. Programmatic Recommendations and Incident Prevention Analysis

Recommendations for Deficiency 1: Vulnerability Management and Patch Governance

1. **Establish a Formal Patch and Vulnerability Management Policy:** Adopt an enterprise policy mandating automated monthly vulnerability scanning across all external-facing and internal assets, paired with strict Service Level Agreements (SLAs) for patch deployment (e.g., critical vulnerabilities patched within 72 hours, high within 14 days).

- **Prevention Impact:** Formalizing scan schedules and patching SLAs ensures third-party applications like MOVEit Transfer are inventoried and updated regularly. Eliminating outdated software versions closes known exposure windows, preventing threat actors from leveraging unpatched vulnerabilities to gain unauthorized access.

2. **Deploy Automated Software Inventory and Centralized Patch Management Solutions:** Implement unified endpoint management and automated software deployment software to maintain an active hardware/software inventory and automate patch distribution.

- **Prevention Impact:** Centralized patch management replaces manual service requests with automated, pre-tested software updates across all campus servers. This ensures critical security updates (such as CVE-2023-34362) are deployed automatically upon vendor release, preventing persistent vulnerability exploitation.

Recommendations for Deficiency 2: Monitoring, Segmentation, and Escalation Governance

1. **Deploy Unified SIEM and EDR Tools Managed by a 24/7 MDR Service:** Implement Endpoint Detection and Response (EDR) software on all endpoints and integrate logs into a Security Information and Event Management (SIEM) platform monitored 24/7/365 by a Managed Detection and Response (MDR) provider.

- **Prevention Impact:** Continuous threat monitoring flags anomalous network behavior, malicious script execution (such as PowerShell spawned from email attachments), and high-volume data exfiltration in real time. Automated EDR agents isolate infected endpoints immediately, preventing lateral malware propagation (like TrickBot and Maze) and stopping exfiltration before data loss occurs.

2. **Implement Micro-Segmentation and Formal Incident Escalation Playbooks:** Enforce strict VLAN micro-segmentation and firewall access control lists (ACLs) to isolate facility networks, while establishing mandatory incident escalation protocols that forbid ransom payments and mandate law enforcement (FBI) and regulatory notification.

- **Prevention Impact:** Logical network micro-segmentation prevents an endpoint infection in a single building from spreading to 100% of hosts or central enterprise servers. Formal escalation playbooks ensure leadership executes lawful, coordinated responses rather than transferring untraceable cryptocurrency to threat actors.

Strategic Action Plan and Implementation Roadmap

Phase 1: Immediate Remediation and Governance (Months 1-2)

- **Action Items:** Draft and adopt the enterprise Patch & Vulnerability Management Policy; enact an executive ban on unauthorized ransom payments; establish mandatory FBI and regulatory notification protocols for all security incidents within Days 1-30. Contract a 24/7 Managed Detection and Response (MDR) partner to oversee network monitoring within Days 31-60.

Phase 2: Technical Tooling and Network Segmentation (Months 3-4)

- **Action Items:** Deploy EDR agents across 100% of university workstations and servers; integrate web application and network logs into a centralized SIEM platform within Days 61-90. Implement micro-segmentation firewall rules between facility networks (such as the College of Healthcare) and central campus infrastructure within Days 91-120.

Phase 3: Automated Lifecycle and Audit Controls (Months 5-6)

- **Action Items:** Deploy an automated software inventory and patch management solution; establish bi-weekly automated vulnerability scanning schedules within Days 121-150. Conduct bi-annual ransomware and incident escalation tabletop drills with IT leadership and the Legal and Compliance Office within Days 151-180.

Direct Executive Next Steps

1. **Policy Approval:** Present the new Patch and Vulnerability Management Policy and Incident Escalation Framework to the Board of Trustees for formal adoption during the next executive session.
2. **MDR Engagement:** Allocate funding to onboard a Managed Detection and Response (MDR) vendor to supply 24/7 monitoring and relieve the four-person IT team of secondary alert monitoring duties.
3. **Network Segmentation:** Direct network engineering staff to configure strict firewall ACLs and VLAN segmentation across satellite campuses and specialized facilities within 60 days.

References

- Family Educational Rights and Privacy Act (FERPA), 20 U.S.C. Section 1232g; 34 CFR Part 99.
- Health Insurance Portability and Accountability Act of 1996 (HIPAA) Security and Privacy Rules, 45 CFR Parts 160 and 164.
- National Institute of Standards and Technology. (2012). Computer Security Incident Handling Guide (NIST Special Publication 800-61, Revision 2). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2012). Conducting Risk Assessments (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce.